RESUM DELS ATACS INFORMÀTICS

- Pretext

La protecció d'un sistema informàtic es basa en la seguretat de tres elements principals: **software**, **hardware** i **dades**. Especialment pel que fa a les dades, aquestes poden patir diversos tipus d'amenaces, com ara: **interrupció**, **intercepció**, **modificació** i **fabricació**.

- Man-in-the-Middle

En criptografia, un atac **Man-in-the-Middle (MitM)** consisteix en què un adversari pot **llegir, inserir i modificar els missatges** entre dues parts sense que aquestes en siguin conscients. Aquest tipus d'atac pot incloure diferents tècniques, com ara:

- **Intercepció de comunicacions** i anàlisi de tràfic.
- **Modificació de missatges** entre l'emissor i el receptor.
- **Repetició de missatges** (replay attacks).
- **Interrupció de la comunicació**, provocant una denegació del servei.

Mètodes de defensa

Per protegir-se d'aquest tipus d'atac s'utilitzen diverses tècniques d'autenticació i seguretat:

- Sistemes de xifrat asimètric o de clau pública: Es basen en dues claus: una **clau privada**, coneguda només pel propietari, i una **clau pública**, que pot ser compartida amb altres entitats sense comprometre la seguretat. Aquest sistema permet operacions unidireccionals com la **signatura electrònica** o l'establiment de sessions segures.
- Autenticació mútua forta: Com es pot observar en els sistemes d'**autenticació de doble factor (2FA)**. En molts serveis es pot activar mitjançant les opcions de seguretat del compte.
  Un altre exemple rellevant són els **certificats TLS/SSL**, que protegeixen les comunicacions a Internet garantint la identitat del servidor i xifrant les dades intercanviades entre el navegador i el lloc web.
- Criteris biomètrics: vist en AEA 2: Sistemes biomètrica.
- Augmentar l'entropia de la contrasenya: L'entropia d'una contrasenya mesura la dificultat d'endevinar-la. Depèn principalment de la **longitud** i la **varietat de caràcters** utilitzats. Contrasenyes llargues i amb diversitat de símbols, números i lletres són molt més segures.

- DoS

Denial of Service (DoS) és un atac basat en la prohibició o denegació del servei a un usuari legítim. Pot servir tant per provocar la interrupció del servei com per comprovar la capacitat de trànsit que pot suportar un ordinador sense perdre estabilitat o afectar els serveis que ofereix.

Quan un servidor és saturat amb més tràfic del que pot gestionar, es produeix una **pèrdua de connectivitat** deguda al consum excessiu d'ample de banda, provocant així la *denegació del servei*.

Aquest tipus d'atac també es pot dur a terme de manera distribuïda, mitjançant un gran volum d'informació enviat des de diversos punts d'Internet, cosa que dóna lloc a un **Distributed Denial of Service (DDoS)**.

- Sniffing

Un **analitzador de paquets** és un programa que captura les trames d'una xarxa quan la interfície de xarxa treballa en **mode promisc**. En aquest mode, la targeta de xarxa accepta **totes les trames que circulen per la xarxa**, incloent-hi aquelles que no van adreçades directament al seu MAC.

Això permet que l'analitzador pugui inspeccionar qualsevol trama d'informació que passi per l'enllaç, ja que a la **capa d'enllaç** la targeta no filtra les trames amb una adreça MAC diferent de la pròpia.

- Spoofing

És una tècnica basada en la **suplantació d'identitat**, utilitzada amb finalitats malicioses o d'investigació. Aquesta tècnica pot manifestar-se de maneres diferents segons la **capa del model de xarxa** en què es produeixi, i qualsevol tipus de tecnologia de comunicació és potencialment susceptible a aquest tipus d'atac.

- Pharming

És una tècnica basada en el **redireccionament dels usuaris** d'una màquina cap a una altra. Així, quan un usuari intenta accedir a un servidor DNS per establir connexió amb una pàgina web, és dirigit al **domini que l'atacant ha especificat**, en lloc del legítim.

És important remarcar que **no és el mateix que el *phishing***. En el phishing es necessita la **interacció explícita de l'usuari**, que és enganyat perquè accedeixi

voluntàriament a un enllaç fraudulent. En canvi, en aquest tipus de redirecció l'usuari és desviat automàticament sense adonar-se'n.